Microsoft Purview Data Loss Prevention (DLP) — Endpoint, Cloud & Email

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview Data Loss Prevention (DLP): Endpoint, Cloud & Email 4

The problem . . . 4

The solution . . . 4

What it delivers . . . 4

Business outcomes . . . 4

Boundaries (so scope is clear) . . . 5

1. Solution Overview — Microsoft Purview Data Loss Prevention (DLP): Endpoint, Cloud & Email 5

What this solution is . . . 5

Why this matters . . . 5

How it works . . . 6

The five DLP locations (and what each controls) . . . 6

The simulate→enforce journey (the core discipline) . . . 7

What you can control . . . 7

Limitations (be honest with buyers) . . . 7

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 8

2. Requirements — Microsoft Purview Data Loss Prevention (DLP) 8

2.1 Licensing sufficient for the DLP features you will use — especially Endpoint DLP . . . 8

2.2 DLP-specific least-privilege roles . . . 9

2.3 Devices onboarded to Purview for Endpoint DLP . . . 9

2.4 A classification intent and a sensitive-information-type inventory . . . 10

2.5 Source data for Exact Data Match (only if EDM is used) . . . 10

2.6 A pilot ring, simulation dwell time, and change control (DLP-specific) . . . 10

2.7 An incident/alert triage owner and destination . . . 11

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12

2. Purview roles (least-privilege) and portal access . . . 12

3. Security & Compliance PowerShell + Graph toolchain . . . 12

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 13

6. A pilot scope and change control . . . 13

3. Implementation Guide — Microsoft Purview Data Loss Prevention (DLP) 14

Phase 0 — Connect and baseline (Assess) . . . 14

Phase 1 — Design the classification layer (SITs & classifiers) . . . 15
Phase 2 — Build the DLP policies in SIMULATION (Configure — no user impact) . . . 15
Phase 3 — Measure and tune (drive false positives down) . . . 16
Phase 4 — Enforce in a pilot ring (Pilot) . . . 16
Phase 5 — Expand and harden (Enforce → Operate) . . . 17
Order-of-operations summary . . . 17
5. Testing & Validation — Microsoft Purview Data Loss Prevention (DLP) 18
Test A — Detection & enforcement (leaks are blocked) . . . 18
Test B — False-positive rate (adoption gate) . . . 19
Test C — Incident / alert handling (the control is operable) . . . 20
Simulation-first & rollback validation . . . 20
Evidence to capture (for the deliverable record) . . . 20
6. Troubleshooting — Microsoft Purview Data Loss Prevention (DLP) 21
Policy / detection . . . 21
Endpoint DLP . . . 22
False positives (the adoption killer) . . . 22
Alerts / incident handling . . . 22
Connectivity / tooling . . . 23
7. Best Practices — Microsoft Purview Data Loss Prevention (DLP) 24
Simulate before you enforce — always . . . 24
Tune for a low false-positive rate (adoption depends on it) . . . 24
Right-size the user experience . . . 24
Endpoint DLP specifics . . . 25
Classification hygiene . . . 25
Operations & governance . . . 25
Stay inside the boundary . . . 25
8. Deliverables Summary — Microsoft Purview Data Loss Prevention (DLP) 26
Documentation . . . 26
PowerShell tools (5) — Security & Compliance PowerShell / Graph . . . 26
Definition of done . . . 27
Appendix A — PowerShell Scripts 29

Executive Summary — Microsoft Purview Data Loss Prevention (DLP): Endpoint, Cloud & Email

The problem

Sensitive data leaves the organization through the channels people use every day — email attachments, "anyone with the link" cloud shares, content pasted into Teams, and files copied to USB or printed from a laptop. Without a working data-loss control, those leaks are invisible until they become an incident. The common failed attempt — switching data-loss controls straight to "block" — floods the help desk with false positives and gets turned off within a week.

The solution

Implement **Microsoft Purview Data Loss Prevention (DLP)** across all five locations — **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)** — using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph. Detection is driven by **sensitive information types** (built-in, custom, **Exact Data Match**, and **trainable classifiers**), and the defining discipline is that **every policy is built and proven in SIMULATION first** — Microsoft's built-in test mode that shows what *would* be blocked, with zero user impact — then tuned for a **low false-positive rate**, then enforced to a **pilot ring**, then expanded. The result: leaks are blocked without blocking the business.

What it delivers

• A mapped **classification layer** — the right detector for each in-scope data category, reusing built-in types and adding custom/EDM/trainable only for real gaps.

• **DLP policies across email, cloud, Teams, and endpoint**, each proven in simulation, tuned, and enforced through policy tips, user justification/override, or block.

• A **measured false-positive rate** kept at/under an agreed threshold — the difference between a control people trust and one they ignore.

• An **incident/alert triage workflow** so every match is actually acted on, with an evidence trail in Activity Explorer and optional SIEM forwarding.

• **Five PowerShell tools** (posture assessment, policy config helper, endpoint-readiness checker, match/false-positive report, scope helper) — read-only or `-WhatIf` by default, no credentials in code.

Business outcomes

• **Leaks blocked** across the channels data actually walks out through — email, cloud sharing, and USB/print on endpoints.

• **Minimal disruption** — simulation-first plus tuning means the control catches leaks without a wave of

false positives, and any policy reverts to simulation instantly if needed.

- **Operable and auditable** — matches raise alerts that are triaged to disposition, with evidence retained.
- **Self-guided at a fraction of consulting cost** — the same method a specialist would use, documented and

tooled to run in-house.

Boundaries (so scope is clear)

DLP is licensing-/plan-dependent — **Endpoint DLP and advanced classifiers require E5 / E5 Compliance and onboarded devices** (verify your tenant). This solution provides the **technical configuration and the evidence**; *which* data categories are in scope, *which* classifiers legally apply, the **enforced action per category**, and the **acceptable false-positive threshold** are **compliance, privacy, and legal determinations**, captured alongside the delivered evidence.

1. Solution Overview — Microsoft Purview Data Loss Prevention (DLP): Endpoint, Cloud & Email

What this solution is

Sensitive data leaves organizations through the everyday channels people already use: an email with a customer spreadsheet attached, a document shared "anyone with the link" from OneDrive or SharePoint, a credit-card number pasted into a Teams chat, or a file copied to a USB stick or printed from a laptop. **Microsoft Purview Data Loss Prevention (DLP)** detects and controls that movement by matching the *content* being shared against **sensitive information types** and **classifiers**, then applying a policy action — audit only, warn the user with a **policy tip**, allow with a business **justification**, or **block** — across **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)**.

This solution is a repeatable, evidence-driven way to implement Purview DLP across all of those locations using only the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party DLP tooling. Its defining discipline is that **every policy is built and proven in SIMULATION mode first** (Microsoft's built-in test mode that evaluates policy against real traffic and shows what *would* have matched, without affecting a single user), tuned for a low false-positive rate, and only then moved to enforcement.

> ***Scope boundary.*** *This solution delivers the **technical method and evidence** for DLP configuration. *Which* data is regulated, *which* classifiers legally apply, and *what* the enforced action must be for a given data category are **business, compliance, privacy, and legal determinations** — deferred to those functions. The solution helps you configure and prove the control; it does not make the policy decision.*

Why this matters

- DLP that is switched straight to **enforce** without simulation is the classic failure: it blocks

legitimate business, floods the help desk, and gets disabled within a week. Simulation-first is the difference between a control that survives and one that is turned off.

• **Endpoint DLP is licensing- and onboarding-dependent** — it requires the right plan and devices onboarded to Purview (shared with Microsoft Defender for Endpoint onboarding). A DLP policy scoped to the Devices location does nothing until the endpoints are actually onboarded and reporting.

• False positives are the enemy of adoption. A built-in credit-card detector that fires on internal reference numbers trains users to ignore every policy tip. Tuning — confidence levels, instance counts, supporting keywords, and Exact Data Match — is what makes the control trusted.

• The same sensitive-information-type library drives DLP, auto-labeling, and insider risk. Getting the classification layer right here pays off across the whole Purview estate.

How it works

1. **Sensitive information types (SITs) and classifiers** define *what* to look for. Purview ships 150+ **built-in SITs** (credit card, SSN/national ID, IBAN, health record numbers, etc.), and you can add **custom SITs** (regex + keyword + confidence), **Exact Data Match (EDM)** SITs (matched against a hashed upload of your real data for near-zero false positives), and **trainable classifiers** (machine-learned categories such as source code, resumes, or financial statements).

1. **DLP policies** bind those SITs to **locations** (Exchange, SharePoint, OneDrive, Teams chat/channel, and **Devices/Endpoint**) with **conditions** (which SIT, how many instances, what confidence), **actions** (audit / notify / restrict / block, restrict USB/print/cloud-app upload on endpoint), and **user experience** (policy tips, allow-with-justification, allow-override).

1. **Simulation mode** runs the policy against live traffic and records what *would* have matched — with or without policy tips shown — so you can see the true hit volume and false positives **before** any enforcement. Every policy in this solution starts here.

1. **Tuning** reduces false positives using confidence levels, instance thresholds, supporting keyword evidence, EDM, and exceptions — measured against the simulation results.

1. **Enforcement** turns the tuned policy on (tips/override/block) in a limited ring, then expands.

2. **Incident/alert handling** — DLP rule matches raise **alerts** in the Purview portal and DLP events flow to **Activity Explorer**; this solution wires the triage, severity, and response workflow so matches are actually acted on.

The five DLP locations (and what each controls)

• **Exchange (email):** outbound/inbound mail matched on content, attachments, and recipients; block or encrypt on match.

• **SharePoint & OneDrive:** documents at rest and when shared; block external sharing on match.

• **Teams chat & channel messages:** sensitive content pasted or shared in messages.

• **Endpoint (Devices):** activities on **onboarded** Windows/macOS devices — copy to USB, copy to network

share, print, upload to unallowed cloud apps/browsers, copy to clipboard, paste to browser. **Requires onboarding and the right licensing.**

• **On-premises / Fabric / Power BI / cloud apps (Defender for Cloud Apps):** additional locations that may be available depending on licensing — **verify availability in your tenant.**

The simulate→enforce journey (the core discipline)

> *Define SITs/classifiers → build each DLP policy in **SIMULATION** (no user impact) → measure hit volume and false positives in **Activity Explorer / DLP alerts** → **tune** (confidence, instance count, keywords, EDM, exceptions) → re-simulate until false positives are acceptable → enable with **policy tips + allow-override/justification** in a **pilot ring** → validate → expand to **enforce (block)** tenant-wide → operate (triage alerts, review overrides, re-tune).*

What you can control

• Which SITs/classifiers are in scope and at what **confidence** and **instance count** they trigger.

• Which **locations** each policy covers and which users/sites/groups are **included or excluded**.

• The **action** per data category (audit → tip → justify → block) — set per compliance's determination.

• Whether users get **policy tips**, can **override** with justification, and what the override says.

• The **pilot ring** enforced first, and the simulation dwell time before enforcement.

Limitations (be honest with buyers)

• **Endpoint DLP requires onboarded devices and the appropriate licensing** (verify your plan — endpoint

DLP and several advanced classifiers are gated behind E5 / the E5 Compliance add-on). A Devices-location policy is inert until onboarding is complete.

• **Some features are in preview** and portal paths **evolve** — this solution flags "verify your

licensing/tenant" rather than asserting availability that may differ in your tenant.

• DLP inspects **content it can classify**; strongly encrypted or unrecognized file formats, or content

below the confidence/instance threshold, will not match. DLP is one control among several, not a guarantee.

• **EDM and trainable classifiers require setup and, for EDM, an ongoing data refresh**; they are the tools

that drive false positives down but they are not zero-effort.

• The **enforced action for a data category is a compliance/legal decision**, not a technical default —

this solution configures and proves the control; the determination is deferred.

Naming convention (used in every doc and script)

Every artifact this solution creates uses `<Purpose> – <Scope> – <Stage>`, reused verbatim across the docs, scripts, and the Purview portal. The standard set:

Artifact	Name
Custom sensitive info type	`Employee ID – Custom SIT – Classification`
EDM schema / SIT	`Customer PII – EDM – Classification`
Email DLP policy (simulation)	`DLP – Email PII – Simulation`
Cloud DLP policy (simulation)	`DLP – SPO+OneDrive+Teams PII – Simulation`
Endpoint DLP policy (simulation)	`DLP – Endpoint PII – Simulation`
Enforced pilot policy	`DLP – All Locations PII – Enforce Pilot`
Pilot user ring	`DLP Pilot Ring – Stage1`
Policy-tip / override text	`DLP Notice – Standard – AllPolicies`
Incident/alert workflow	`DLP Alerts – Triage – Operations`

The standard deployment model

> ***Assess*** *current data exposure and classification intent →* ***Design*** *SITs/classifiers, policies, and user experience →* ***Configure*** *SITs and policies* ***in simulation*** *→* ***Pilot*** *(simulate → tune → enforce to a ring) →* ***Validate*** *against pass/fail gates (leaks blocked, false-positive rate low, incidents handled) →* ***Expand*** *to tenant-wide enforcement and ongoing operations. Every high-impact change is piloted in simulation first, with a documented rollback.*

2. Requirements — Microsoft Purview Data Loss Prevention (DLP)

These are the **solution-specific** prerequisites for implementing Purview DLP across endpoint, cloud, and email. They build on — and do not repeat — the six shared prerequisites in `global-requirements-purview.md` (tenant + compliance licensing, least-privilege Purview roles, S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope + change control). Verify each item below before starting the Implementation Guide.

For every requirement: **Description** (what it is), **Why required**, **How to verify**, **How to implement if missing**.

2.1 Licensing sufficient for the DLP features you will use — especially Endpoint DLP

- **Description:** DLP for **Exchange/SharePoint/OneDrive/Teams** and **built-in SITs** is broadly

available, but **Endpoint DLP**, **advanced/custom classifiers**, **Exact Data Match**, and **trainable classifiers** are **plan-gated** — typically **Microsoft 365 E5** or the **E5 Compliance** add-on (some

capabilities are in **preview**). This extends GR-#1 with the DLP-specific plan detail.

- **Why required:** A DLP policy scoped to a location or using a classifier your plan doesn't include will not function. Endpoint DLP in particular is an E5/E5-Compliance capability.
- **How to verify:** In the **Microsoft 365 admin center** confirm the subscription/add-ons; in the **Purview portal** → **Data Loss Prevention** confirm the **Endpoint DLP** and **Devices** location and the classifier types you intend to use are visible. **Flag "verify your licensing/tenant"** — availability evolves.
- **How to implement if missing:** Acquire/assign the required licensing (E5 or E5 Compliance) before building endpoint or advanced-classifier policies; scope the initial rollout to features your plan covers.

2.2 DLP-specific least-privilege roles

- **Description:** The **DLP role groups** in the Purview portal — **Compliance Administrator** or **Compliance Data Administrator** to create/manage DLP policies, **DLP Compliance Management** for policy management, **View-Only DLP Compliance Management** for read-only review, and the **Data Loss Prevention** role for alert/incident handling. Global Administrator only where genuinely required. Extends GR-#2.
- **Why required:** Purview enforces fine-grained role groups; DLP configuration and alert triage require the matching role, and least privilege keeps the blast radius small.
- **How to verify: Purview portal** → **Settings** → **Roles & scopes** → **Permissions** (or Microsoft Purview roles) — confirm your account's role-group membership includes the DLP roles you need.
- **How to implement if missing:** Assign the least-privilege DLP role group under change control; separate policy authors from alert triagers where possible.

2.3 Devices onboarded to Purview for Endpoint DLP

- **Description:** Endpoint DLP monitors activities on **onboarded Windows 10/11 and macOS devices**. Onboarding is done in **Purview portal** → **Settings** → **Device onboarding** (or via Intune / a script / Group Policy), and is **shared with Microsoft Defender for Endpoint onboarding** — devices already onboarded to Defender for Endpoint are onboarded for Endpoint DLP.
- **Why required:** A DLP policy scoped to the **Devices** location does nothing on a device that is not onboarded and reporting. Onboarding is the hard prerequisite for any endpoint control.
- **How to verify: Purview portal** → **Settings** → **Device onboarding** → **Devices** shows onboarded devices; confirm target devices appear and are reporting. On a device, confirm the onboarding state per Microsoft's documented method.
- **How to implement if missing:** Onboard devices via the Purview device-onboarding package, Intune, or

Group Policy; confirm the minimum OS build and any required Antimalware/AV state per Microsoft docs before scoping endpoint policies.

2.4 A classification intent and a sensitive-information-type inventory

- **Description:** A documented view of **what sensitive data you are protecting** (e.g. payment card data,

national IDs, health identifiers, customer PII, source code) mapped to the **SITs/classifiers** that detect it — built-in SITs where they fit, **custom SITs / EDM / trainable classifiers** where they don't. Extends GR-#4.

- **Why required:** DLP policies key off SITs; without knowing which data matters and which SIT detects it

(at what confidence and instance count), policies are guesswork and generate false positives.

- **How to verify: Purview portal** → **Data classification** → **Classifiers** → **Sensitive info types** lists

built-in and custom SITs; confirm the ones you need exist (or are planned). Confirm the data categories with the data owners.

- **How to implement if missing:** Build the SIT inventory (this solution's Discovery script assesses

built-in SIT coverage); plan custom SITs / EDM / trainable classifiers for categories not covered.

2.5 Source data for Exact Data Match (only if EDM is used)

- **Description:** For **EDM** SITs, a **sensitive data table** (e.g. an export of customer records) and a

workstation with the **EDM Upload Agent** to hash and upload it — the raw data never leaves your control; only salted hashes are uploaded.

- **Why required:** EDM matches against *your actual data*, which is what drives false positives to near

zero — but it requires the schema, the hashed upload, and a **refresh cadence** as the data changes.

- **How to verify:** Confirm the source table, the EDM schema, the upload agent host, and a scheduled

refresh. **Purview portal** → **Data classification** → **Exact data matches** shows configured EDM schemas.

- **How to implement if missing:** Define the EDM schema and refresh process (deferred to the data owner

for *which* fields are in scope); if EDM is not in your plan or not needed, use custom SITs with confidence/keyword tuning instead.

2.6 A pilot ring, simulation dwell time, and change control (DLP-specific)

- **Description:** A named **pilot user/device ring**, an agreed **simulation dwell time** (how long each

policy runs in simulation before enforcement — long enough to capture representative traffic), and the **change-control window** for moving simulation → enforce. Extends GR-#6.

- **Why required:** DLP is high-impact; enforcing without a simulation baseline and a limited ring is how

DLP breaks the business. The house model mandates **simulation first**, then a ring, then expand.

- **How to verify:** Confirm the pilot ring membership, that **simulation mode** is selected on each new

policy, and the approval path to enforce.

- **How to implement if missing:** Define the ring and dwell time and agree change control before enabling

any enforcement action.

2.7 An incident/alert triage owner and destination

- **Description:** A named owner (or queue) for **DLP alerts** raised in **Purview portal → Data loss

prevention → Alerts**, plus where DLP events are reviewed (**Activity Explorer**) and, optionally, where they are forwarded (SIEM/Microsoft Sentinel via the Office 365 Management Activity API / Defender connectors). Severity and response actions defined.

- **Why required:** A DLP match with no one to triage it is not a control. Alerts and Activity Explorer are

where matches surface; someone must own triage, severity, and response.

- **How to verify:** Confirm the triage owner/queue, the alert-severity scheme, and any SIEM forwarding is

configured.

- **How to implement if missing:** Assign the owner, define severity/response, and (optionally) wire SIEM

forwarding before enforcement generates real alerts.

Requirements summary

#	Requirement	Gate
GR 1–6	Category prerequisites (`global-requirements-purview.md`)	Tenant/licensing, roles, toolchain, scope, stakeholders, pilot + change control
2.1	DLP/Endpoint licensing (E5 / E5 Compliance; verify)	Endpoint & advanced classifiers available
2.2	DLP least-privilege roles	Author + triage roles assigned
2.3	Devices onboarded to Purview	Endpoint location functional
2.4	Classification intent + SIT inventory	Policies key off correct SITs
2.5	EDM source data + agent (if used)	Near-zero-FP matching where needed
2.6	Pilot ring + simulation dwell + change control	Simulate-first enforced
2.7	Alert/incident triage owner + destination	Matches are acted on

> ***Deferred to compliance/privacy/legal:*** *which data categories are in scope, which classifiers legally apply, the enforced action per category, and any regulatory applicability. This solution provides the technical configuration and evidence, not the determination.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

• **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

• **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

• **Why required:** Purview policies key off the in-scope workloads and the classification scheme.

• **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

• **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

• **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

• **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

• **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.

• **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview Data Loss Prevention (DLP)

This is the exact, ordered procedure to implement Purview DLP across **email, cloud, Teams, and endpoint** — every policy built in **SIMULATION** first, tuned, then enforced in a ring, then expanded. Portal paths and cmdlets are from Microsoft's public documentation; **licensing-/plan-dependent features and evolving portal paths are flagged "verify your licensing/tenant"** and are never asserted for your tenant. Do the phases in order. Each phase names its artifacts (from the Overview naming table), states a **pass/fail gate**, and gives a **rollback**.

> ***Automation.*** *The five delivered PowerShell tools run through **Security & Compliance PowerShell** (`Connect-IPPSSession`) and **Microsoft Graph**. They are **read-only or** `-WhatIf` **by default**; writes require an explicit `-Commit` switch. No credentials are stored in code.*
>
> ***Determinations deferred.*** **Which* data categories are in scope, *which* classifiers legally apply, and the *enforced action* per category are **compliance/privacy/legal** decisions. This guide configures and proves the control; capture those decisions before Phase 3.*

Phase 0 — Connect and baseline (Assess)

1. **Connect the toolchain** (GR-#3). On the admin workstation:

```
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force   # provides Connect-IPPSSession
Connect-IPPSSession -UserPrincipalName admin@contoso.com            # Security & Compliance PowerShell
Connect-MgGraph -Scopes 'Organization.Read.All','InformationProtectionPolicy.Read' -NoWelcome
```

1. **Run the posture assessment** (delivered script #1, read-only):

```
.\PURVDLP-Discovery.ps1 -CsvPath .\PURVDLP-Posture.csv
```

It reports existing DLP policies and their mode, built-in vs custom SIT coverage, and licensing/endpoint readiness signals.

1. **Confirm licensing and endpoint readiness** (Req 2.1, 2.3): confirm E5/E5-Compliance where endpoint or

advanced classifiers are needed, and that target devices are **onboarded** (script #3 checks this).

Pass/fail gate: you have a written baseline (existing policies + modes), a SIT coverage map, and confirmed licensing + endpoint onboarding for the locations you will target. **Rollback:** none (read-only).

Phase 1 — Design the classification layer (SITs & classifiers)

Decide, per in-scope data category, which detector applies. Do **not** invent SITs — use built-in where they fit; build custom/EDM/trainable only for gaps.

1. **Map built-in SITs first.** In **Purview portal → Data classification → Classifiers → Sensitive info types**, confirm the built-in SITs for your categories (e.g. *Credit Card Number*, *U.S. Social Security Number (SSN)*, *ABA Routing Number*, national-ID SITs). Note each SIT's** confidence levels **and default** instance count**.

1. **Author custom SITs for gaps.** For a category with no built-in match (e.g. an internal Employee ID), create `Employee ID – Custom SIT – Classification` with a **regex primary pattern**, **supporting keywords**, a **confidence level**, and a **character proximity**. Portal: **Classifiers** → **Sensitive info types** → **Create sensitive info type**. Test it against sample text in the wizard's **Test** step.

1. **Configure EDM only where near-zero false positives are required** (Req 2.5). Define the schema (`Customer PII – EDM – Classification`), hash-and-upload the source table with the **EDM Upload Agent**, and set a **refresh cadence**. Portal: **Data classification** → **Exact data matches**. *Which fields are in scope is the data owner's determination.*

1. **Add trainable classifiers where a category is conceptual, not pattern-based** (e.g. source code, resumes) — use a built-in trainable classifier or train a custom one on sample content. Verify availability against your plan.

Pass/fail gate: every in-scope data category maps to a named, tested SIT/classifier at a chosen confidence and instance count. **Rollback:** delete unused custom SITs/EDM schemas (they have no effect until referenced by a policy).

Phase 2 — Build the DLP policies in SIMULATION (Configure — no user impact)

Create **one policy per location group**, each in **simulation mode**. Simulation evaluates the policy against real traffic and records what *would* match, with **no** enforcement and (optionally) with policy tips shown.

1. **Email DLP policy —** `DLP – Email PII – Simulation`**.**

Portal: **Data loss prevention** → **Policies** → **Create policy** → custom or a category template → **Locations: Exchange email only** → rule: condition *Content contains* the SITs from Phase 1 at the chosen confidence/instance count → action *Restrict access or encrypt* (kept inert by simulation) → **Policy mode: Run the policy in simulation mode** (optionally *with policy tips*). Finish.

1. **Cloud DLP policy —** `DLP – SPO+OneDrive+Teams PII – Simulation`**.**

Same flow → **Locations: SharePoint sites, OneDrive accounts, Teams chat and channel messages** → conditions as above → action *Restrict access* (block external sharing on match) → **simulation mode**.

1. **Endpoint DLP policy —** `DLP – Endpoint PII – Simulation` (requires onboarded devices + licensing).

Same flow → **Locations: Devices** → conditions as above → **endpoint activities to audit/restrict**: *copy to USB/removable media*, *copy to network share*, *print*, *upload to unallowed cloud apps/browser*, *copy to clipboard*, *paste to browser* → **simulation mode**. Confirm the Devices location is selectable (if not, revisit licensing/onboarding — Req 2.1/2.3).

1. **Set the user experience** consistently: define `DLP Notice – Standard – AllPolicies` policy-tip text

and enable **allow override with justification** where compliance permits — but note tips/overrides only *appear* once a policy is enforced; in simulation they are captured, not shown to end users unless "simulation with policy tips" is selected.

1. **Verify with the config helper** (delivered script #2, `-WhatIf` by default):

```
.\PURVDLP-Config.ps1 -PolicyName 'DLP – Email PII – Simulation' -WhatIf
```

Run with `-Commit` only to apply an intended change; the script never leaves a policy in enforce mode.

Pass/fail gate: all three policies exist and are confirmed in **simulation** (script #1/#2 report `Mode = Enable → TestWithoutNotifications / TestWithNotifications`, i.e. simulation), scoped to the correct locations and SITs. **Rollback:** delete the simulation policy — simulation has no user impact, so removal is clean.

Phase 3 — Measure and tune (drive false positives down)

Let each policy run in simulation for the agreed **dwell time** (Req 2.6) to capture representative traffic.

1. **Review what matched. Purview portal** → **Data loss prevention** → **Alerts** (simulation alerts) and

Data classification → **Activity explorer** (filter to DLP activities) show every simulated match with the file/message, the SIT, and the confidence. Export with the reporting script:

```
.\PURVDLP-Report.ps1 -Days 14 -CsvPath .\PURVDLP-Matches.csv
```

1. **Classify each match** as true positive or **false positive** and identify the false-positive drivers

(e.g. a built-in *Credit Card* SIT firing on internal reference numbers).

1. **Tune** to reduce false positives without losing true positives:

• Raise the **confidence level** (e.g. medium → high) so only high-confidence matches count.

• Raise the **instance count** (e.g. require ≥10 card numbers, not 1) for bulk-leak focus.

• Add **supporting keywords / proximity** to custom SITs so context is required.

• Introduce **EDM** for categories where pattern SITs over-match.

• Add **exceptions** (e.g. exclude a specific internal sender/site) where justified.

1. **Re-simulate** after each tuning change and re-measure. Repeat until the false-positive rate meets the

validation gate (see Testing).

Pass/fail gate: measured false-positive rate is at/under the agreed threshold on the simulation sample, with true positives still detected. **Rollback:** revert the last tuning change (script #2 `-WhatIf` shows the diff before `-Commit`).

Phase 4 — Enforce in a pilot ring (Pilot)

1. **Scope to the pilot ring.** Add `DLP Pilot Ring – Stage1` (users) and pilot devices as the **included**

scope on each policy (all other users/devices excluded for now).

1. **Move the ring to enforcement.** Change **Policy mode** from *simulation* to **Turn it on / Enforce**.

Start with **policy tips + allow-override (justification)** rather than hard block, so the pilot can report false negatives/positives while retaining a business escape hatch.

1. **Confirm enforcement is live** for the ring only (script #1 reports mode `Enable` and the scoped

identities). Confirm end users in the ring now see the `DLP Notice – Standard – AllPolicies` tip on a test match.

1. **Handle incidents.** Wire `DLP Alerts – Triage – Operations`: assign the alert owner/queue (Req 2.7),

set severities, and (optionally) forward to SIEM/Sentinel. Triage a real simulated/pilot alert end-to-end to prove the workflow.

Pass/fail gate: the pilot ring is enforced (tips shown, overrides captured), matches raise alerts, and the triage workflow produces a dispositioned incident. No enforcement outside the ring. **Rollback:** set the policy back to **simulation mode** (single setting) — instantly removes enforcement with no data change.

Phase 5 — Expand and harden (Enforce → Operate)

1. **Expand scope** from the ring to the full intended population once the pilot gate passes, keeping

documented exclusions.

1. **Escalate the action** per compliance's determination — e.g. move a category from *tip + override* to

block where required — one category/location at a time, re-validating after each.

1. **Operationalize:** schedule the reporting script for a recurring false-positive/alert review, review

user overrides (are people justifying legitimately or bypassing?), refresh **EDM** data on cadence, and re-tune as data and behavior change.

1. **Validate end-to-end** with the delivered testing procedure (next section) and record the pass/fail

evidence.

Pass/fail gate: enforcement live across the intended scope with the compliance-mandated action per category; false-positive rate steady/low; alerts triaged on cadence; overrides reviewed. **Rollback:** any policy can be returned to **simulation** at any time as an immediate, non-destructive safety switch; individual policies can be disabled without affecting others.

Order-of-operations summary

Phase	Do	Artifact(s)	Gate	Rollback
0 Assess	Connect, baseline, confirm licensing/onboarding	Posture CSV	Baseline + readiness confirmed	n/a (read-only)

Phase	Do	Artifact(s)	Gate	Rollback
1 Design	Map/build SITs, EDM, classifiers	Custom SIT / EDM schema	Every category → tested detector	Delete unused SIT/EDM
2 Configure	Build 3 policies in **simulation**	Email/Cloud/Endpoint sim policies	All in simulation, correct scope	Delete sim policy
3 Tune	Measure + reduce false positives	Matches CSV	FP rate ≤ threshold	Revert tuning change
4 Pilot	Enforce to ring, wire alerts	Pilot ring, alert triage	Ring enforced, incident dispositioned	Back to simulation
5 Expand	Broaden scope, escalate to block, operate	Enforced policies	Full-scope enforce, low FP, alerts triaged	Simulation / disable

5. Testing & Validation — Microsoft Purview Data Loss Prevention (DLP)

Validate the DLP implementation against explicit **pass/fail gates**. The three headline gates for this solution are: **(A) leaks are blocked**, **(B) the false-positive rate is low**, and **(C) incidents are handled**. Run every test with **non-real, clearly-fake sample data** (e.g. the Microsoft-documented test credit-card number `4111 1111 1111 1111`) — never real customer/employee data — and record the evidence.

> *All tests assume the policies from the Implementation Guide, first proven in **simulation** and then enforced to the **pilot ring**. Endpoint tests require an **onboarded** device (Req 2.3).*

Test A — Detection & enforcement (leaks are blocked)

#	Test	Steps	Pass condition
A1	Email match blocked	From a pilot-ring user, send an email to an **external** recipient containing enough fake SIT instances to meet the threshold.	Message is blocked/encrypted per the enforced action; sender sees the policy tip; a DLP alert is raised.
A2	SharePoint/OneDrive external share blocked	As a ring user, upload a file with the fake SIT and attempt to share it **externally**.	External sharing is blocked/restricted on match; event appears in Activity Explorer.
A3	Teams message match	Paste fake SIT content into a Teams chat/channel covered by the policy.	Message is blocked or tipped per the enforced action; event logged.

#	Test	Steps	Pass condition
A4	Endpoint — USB copy	On an onboarded ring device, copy a file containing the fake SIT to **removable media**.	Activity is audited/blocked per policy; endpoint DLP event appears in Activity Explorer.
A5	Endpoint — print / cloud upload	On the ring device, attempt to **print** the file and **upload** it to an unallowed cloud app/browser.	Each activity is audited/restricted per policy; events logged.
A6	Below-threshold negative	Send content with **fewer** SIT instances than the threshold (or lower confidence).	Correctly **not** matched — confirms the threshold/confidence tuning holds.

Gate A (pass): A1–A5 each produce the enforced action and a logged event; A6 correctly does not match.

Test B — False-positive rate (adoption gate)

#	Test	Steps	Pass condition
B1	Simulation FP baseline	Over the agreed dwell time, export simulation matches (`PURVDLP-Report.ps1 -Days <n>`) and classify each as TP/FP.	**False-positive rate** ≤ **the agreed threshold** (define with compliance; a common target is ≤10% of matches, or an absolute FP count the triage team can absorb).
B2	Legitimate-traffic negative	Run representative legitimate business content (no real sensitive data) through the covered channels.	Legitimate traffic is **not** matched — no spurious tips/blocks.
B3	Post-tuning re-measure	After each tuning change (confidence↑, instance count↑, keywords, EDM, exceptions), re-simulate and re-measure.	FP rate trends **down** while true positives (Test A) still fire.
B4	Override sanity	In the pilot ring, review captured **allow-with-justification** overrides.	Overrides are legitimate business justifications, not routine bypass — if routine, re-tune or re-scope.

Gate B (pass): measured FP rate at/under threshold on the simulation sample with true positives intact.

Test C — Incident / alert handling (the control is operable)

#	Test	Steps	Pass condition
C1	Alert raised	Trigger a policy match (Test A1/A4).	A DLP **alert** appears in **Purview** → **Data loss prevention** → **Alerts** with the correct policy, severity, and evidence.
C2	Triage workflow	The `DLP Alerts – Triage – Operations` owner/queue picks up the alert, sets status, and dispositions it.	Alert moves through the defined states to a resolved disposition by the named owner.
C3	Activity Explorer trail	Locate the same event in **Data classification** → **Activity explorer**.	Full evidence trail present (user, location, SIT, action) for investigation.
C4	SIEM forwarding (if configured)	Confirm the DLP event reaches the SIEM/Sentinel destination (Req 2.7).	Event present in the downstream system with usable fields.

Gate C (pass): matches raise alerts, alerts are triaged to disposition by the owner, and the evidence trail (and SIEM forward, if used) is present.

Simulation-first & rollback validation

#	Test	Pass condition
S1	Nothing enforced outside the ring	Users/devices **outside** `DLP Pilot Ring – Stage1` experience no blocking during pilot.
S2	Instant rollback	Setting any enforced policy back to **simulation mode** immediately removes enforcement with no data change (verify a previously-blocked action now only simulates).
S3	Scripts are safe-by-default	`PURVDLP-Config.ps1` run **without** `-Commit` makes no change (`-WhatIf` output only); discovery/report/onboarding-check scripts are read-only.

Evidence to capture (for the deliverable record)

• Baseline posture CSV (Phase 0) and the SIT coverage map.

• Simulation match export + TP/FP classification and the computed **false-positive rate** before/after tuning (Gate B).

• Screenshots/log of Test A enforcement actions and the raised alerts (Gate A/C).

• The dispositioned incident from Test C2 and, if used, the SIEM forward (C4).

• Confirmation that outside-ring users were unaffected (S1) and that simulation rollback works (S2).

> ***Determination boundary.*** *These tests prove the **control works**. Whether a given category's enforced action and FP threshold are *acceptable* is a compliance/privacy/legal sign-off, captured alongside the evidence above.*

6. Troubleshooting — Microsoft Purview Data Loss Prevention (DLP)

Symptom-first fixes for the failures you actually hit implementing DLP across email, cloud, Teams, and endpoint. Most problems are one of: a policy not matching, the endpoint location unavailable, too many false positives, or matches that raise no alert.

Policy / detection

A DLP policy matches nothing even though the content clearly contains sensitive data.

• Confirm the policy is actually **enabled and in a mode that evaluates** — a *disabled* policy does nothing; a **simulation** policy evaluates and logs but does not block. Check with `PURVDLP-Discovery.ps1` (Mode column).

• Check the **instance count and confidence** on the rule — if it requires ≥10 matches at High confidence and your test has 1, it correctly won't fire. Lower the threshold for testing, or add more sample instances.

• **Policy propagation takes time** — newly created/changed DLP policies can take **up to ~1 hour (and longer for some locations)** to take effect. Wait before concluding it's broken.

• Confirm the **location scope** includes where you're testing (e.g. the specific site/user), and that the test identity isn't in an **exclusion**.

A custom SIT never matches.

• Test the SIT's **regex + keywords** in the SIT wizard's **Test** step with known-matching text. A too-strict regex, wrong **character proximity**, or a required keyword that isn't present will suppress all matches. Loosen and re-test incrementally.

Matches appear in simulation but nothing is blocked.

• That is **correct** — simulation logs what *would* happen without enforcing. To block, move the policy to

enforce for the pilot ring (Implementation Phase 4). If you expected blocking, you're still in simulation.

Endpoint DLP

The Devices/Endpoint location isn't available when creating a policy.

- **Licensing:** Endpoint DLP requires the appropriate plan (E5 / E5 Compliance) — run `PURVDLP-EndpointReadiness.ps1` for the licensing signal and **verify in the admin center**.
- **Onboarding:** the Devices location depends on **onboarded devices** — confirm in **Purview portal → Settings → Device onboarding**. No onboarded devices → the location does nothing even if selectable.

Endpoint policy is enforced but device activities (USB/print/upload) aren't caught.

- Confirm the specific **device is onboarded and reporting** (portal device list), meets the **minimum OS build**, and — for some activities — that the required agent/AV prerequisites per Microsoft docs are met.
- Confirm the **activity is in scope** of the rule (e.g. "copy to USB" is enabled) and that the app/browser or network path isn't on an **allowed/exception** list.
- Allow for **reporting latency** — endpoint events can take time to surface in Activity Explorer.

False positives (the adoption killer)

Users are getting policy tips on legitimate, non-sensitive content.

- Export matches with `PURVDLP-Report.ps1 -CsvPath ...`, classify TP/FP, and identify the driver.
- **Raise confidence** (medium→high) and/or **instance count** so single/low-confidence hits don't fire.
- Add **supporting keywords/proximity** to custom SITs so context is required.
- For a built-in SIT that over-matches your internal identifiers, move that category to **Exact Data Match** so only your real data matches.
- Add a targeted **exception** where justified (specific sender/site) — narrowly, with a documented reason.
- Re-simulate after each change and re-measure — don't stack multiple changes blind.

Alerts / incident handling

Policy matches occur but no alert appears / no one is notified.

- Confirm **alerts are configured** on the rule (alert on match, threshold) and check **Purview → Data loss prevention → Alerts**. Some low-severity matches aggregate rather than alert per event.
- Confirm **audit logging is enabled** in the tenant — the report script and Activity Explorer rely on it.

• Confirm the **triage owner/queue** (`DLP Alerts – Triage – Operations`) exists and, if forwarding to

SIEM/Sentinel, that the connector is healthy (Req 2.7).

The report script returns no matches.

- **Audit log latency:** DLP events can take time to appear; widen `-Days` and re-run.
- Freshly created policies need **dwell time** — there may simply be no matches yet.
- Confirm **audit logging is on** and your account has the **View-Only DLP / audit** role.

Connectivity / tooling

`Connect-IPPSSession` **or a DLP cmdlet fails.**

• Ensure the **ExchangeOnlineManagement** module is installed/updated and you're using a **modern-auth /

MFA-capable** admin.

• Confirm the account holds the required **DLP role** (Compliance Administrator / Compliance Data

Administrator / DLP Compliance Management) — a missing role surfaces as "cmdlet not recognized" or access denied.

A script made an unexpected change.

• The delivered scripts are **read-only or** `-WhatIf` **by default**; writes require `-Commit`. If a change

landed, it was committed intentionally — the config helper never leaves a policy in **enforce**, so the safe recovery is always to set the policy back to **simulation** in the portal (one setting, no data change).

Fast triage table

Symptom	First check
Policy matches nothing	Mode (disabled/sim), instance count/confidence, propagation time, scope/exclusion
Custom SIT never fires	Test regex+keywords+proximity in the SIT wizard
Nothing blocked	Still in **simulation** — that's expected; enforce the ring to block
Devices location missing	Licensing (E5/E5 Compliance) + device **onboarding**
Endpoint activity not caught	Device onboarded/reporting, activity in scope, allowed-app/network exceptions
Too many false positives	Raise confidence/instance count, add keywords/EDM, exceptions, re-simulate
No alert on match	Alert config on rule, audit logging on, triage owner, SIEM connector
Report returns nothing	Audit latency/dwell time, audit logging on, role

Symptom	First check
Cmdlet/connect fails	Module updated, modern auth, correct DLP role

7. Best Practices — Microsoft Purview Data Loss Prevention (DLP)

Field-tested practices for running Purview DLP across endpoint, cloud, and email so the control stays trusted, effective, and low-noise. These complement the Implementation and Testing guides.

Simulate before you enforce — always

• **Never** switch a new or materially changed DLP policy straight to enforce. Run it in **simulation** first, long enough to capture representative traffic (Req 2.6), and read the results before enabling.

• Use **simulation with policy tips** on the pilot ring when you want end-user feedback before hard block.

• Treat **simulation mode as your permanent safety switch**: any enforced policy can be returned to simulation in one setting, instantly removing enforcement with no data change — this is your rollback.

Tune for a low false-positive rate (adoption depends on it)

• Start at **higher confidence** and a **realistic instance count** — a single credit-card match is noise; ten in one file is a leak. Bulk-exfiltration thresholds cut false positives dramatically.

• Add **supporting keywords and proximity** to custom SITs so context is required, not just a pattern.

• Use **Exact Data Match** for categories where pattern SITs over-fire — it matches your *actual* data and drives false positives toward zero, at the cost of an upload + refresh cadence.

• Every false positive that reaches a user erodes trust in **every** policy tip. Budget for a tuning cycle, not a one-time build.

Right-size the user experience

• Show **clear, actionable policy tips** — tell the user *why* and *what to do*, in business language, not a compliance error code. Reuse one standard notice (`DLP Notice – Standard – AllPolicies`).

• Prefer **allow-with-justification / override** over hard block for categories where legitimate business exceptions exist, then **review the overrides** — routine overriding means the policy is mis-scoped.

• Reserve **hard block** for the categories where compliance/legal require it; escalate to block one category at a time, re-validating each.

Endpoint DLP specifics

• **Onboarding is the gate.** A Devices policy is inert until the device is onboarded (shared with Defender for Endpoint) and reporting — verify onboarding before blaming the policy.

• Roll endpoint controls out **audit-first**: audit USB/print/cloud-upload activities before restricting, so you see real usage patterns and avoid blocking legitimate workflows.

• Mind **unallowed vs allowed apps/browsers and network exceptions** — configure the allowed-app and network-path lists so sanctioned tools aren't caught alongside exfiltration paths.

Classification hygiene

• **Reuse built-in SITs** wherever they fit; build custom/EDM/trainable only for genuine gaps — fewer, well-tuned detectors beat a sprawl of overlapping ones.

• **Version and document** each custom SIT/EDM schema (pattern, confidence, keywords, owner) so tuning changes are traceable.

• **Refresh EDM data** on a schedule — stale EDM data silently degrades matching.

Operations & governance

• Give DLP **alerts an owner and an SLA** (Req 2.7). Match volume without triage is not a control. Forward to SIEM/Sentinel where central SecOps needs visibility.

• Review **Activity Explorer** and the false-positive rate on a **recurring cadence**; re-tune as data and behavior drift.

• Enforce **least-privilege roles** and, where possible, **separate policy authors from alert triagers**.

• Keep a **change log** of every simulate→enforce transition and every action escalation, with the compliance sign-off attached.

Stay inside the boundary

• DLP is **one control**, not a guarantee — it inspects content it can classify; combine with sensitivity labels, encryption, and insider-risk where the risk warrants.

• **Verify licensing/tenant** before relying on any endpoint or advanced-classifier capability — plans and portal paths evolve; don't assume a feature is present.

• The **enforced action and the acceptable false-positive threshold per category are compliance/legal determinations** — you provide the technical control and the evidence; they own the decision.

8. Deliverables Summary — Microsoft Purview Data Loss Prevention (DLP)

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The DLP model — SITs/classifiers, the five locations (email, SharePoint, OneDrive, Teams, endpoint), policy tips/overrides, and the simulate→enforce journey; naming convention.
Requirements Guide	Solution-specific prerequisites (DLP/Endpoint licensing, DLP roles, device onboarding, classification intent, EDM source data, pilot ring, alert triage owner) each with verify/implement steps, on top of the six category prerequisites.
Implementation Guide	The exact ordered phases: connect/baseline → design SITs → build policies **in simulation** → tune false positives → enforce to a pilot ring → expand; each phase named, gated, and with a rollback.
Testing & Validation	Pass/fail gates for the three headline outcomes — leaks blocked (A), low false-positive rate (B), incidents handled (C) — plus simulation-first and rollback checks, all with fake test data.
Troubleshooting Guide	The common failure modes (policy not matching, endpoint location missing, floods of false positives, no alerts) and how to resolve them.
Best Practices	Simulate-first discipline, false-positive tuning, user-experience design, endpoint specifics, classification hygiene, and operations/governance.
Executive Summary	One-page business framing for approvers.

PowerShell tools (5) — Security & Compliance PowerShell / Graph

All tools are **read-only or `-WhatIf` by default**; writes require an explicit `-Commit`. No credentials are stored in code. They connect via `Connect-IPPSSession` and/or `Connect-MgGraph`.

#	Script	Role	Default safety
1	**PURVDLP-Discovery.ps1**	DLP posture + sensitive-info-type coverage assessment: existing policies and their mode, built-in vs custom SIT coverage, licensing/endpoint readiness signals.	Read-only
2	**PURVDLP-Config.ps1**	DLP policy configuration helper: creates/updates a policy **in simulation mode** and reports the intended change.	`-WhatIf` (writes need `-Commit`; never leaves a policy in enforce)
3	**PURVDLP-EndpointReadiness.ps1**	Endpoint-DLP onboarding/readiness checker: onboarded-device count/state and whether the Devices location is usable.	Read-only
4	**PURVDLP-Report.ps1**	DLP match / false-positive tuning report: exports simulation/enforcement matches for TP-vs-FP classification and rate calculation.	Read-only
5	**PURVDLP-Set-Scope.ps1**	Scope/config helper: reports and (with `-Commit`) adjusts a policy's included/excluded users/groups (e.g. the pilot ring).	`-WhatIf` (writes need `-Commit`)

Definition of done

• Sensitive information types/classifiers mapped for every in-scope data category (built-in reused; custom/

EDM/trainable only for gaps).

• Email, cloud (SPO/OneDrive/Teams), and endpoint DLP policies built and **proven in simulation**.

• False-positive rate measured and tuned to at/under the agreed threshold (Gate B).

• Enforcement live for the pilot ring with policy tips + override, then expanded per compliance's action determination (Gate A).

• DLP alerts raised, triaged to disposition, and evidence trailed in Activity Explorer (Gate C).

• Simulation-rollback and safe-by-default scripts verified; change log and compliance sign-offs captured.

Boundary: *the solution delivers the technical control and the evidence. The* ***data categories in scope, the classifiers that legally apply, the enforced action per category, and the acceptable false-positive threshold*** *are compliance/privacy/legal determinations, captured alongside the evidence.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

PURVDLP-Config.ps1

Purpose: Creates a new DLP compliance policy (and a matching content rule for one or more sensitive information types) in SIMULATION mode, or updates an existing policy's rule, across the chosen locations (Exchange / SharePoint / OneDrive / Teams / Endpoint). Safe by default: with -WhatIf it only reports the intended change; it applies nothing unless -Commit is passed, and it NEVER creates or leaves a policy in enforce (Enable) mode — simulation only. Enforcement is a deliberate, separate portal/change-control step. HOW TO RUN Preview an Exchange+Cloud simulation policy for the built-in Credit Card SIT: powershell -File .\PURVDLP-Config.ps1 -PolicyName 'DLP - Email PII - Simulation' `-Locations Exchange -SensitiveTypes 'Credit Card Number' -MinCount 10 -Confidence High -WhatIf Actually create it (still simulation mode): powershell -File .\PURVDLP-Config.ps1 -PolicyName 'DLP - Email PII - Simulation'` -Locations Exchange -SensitiveTypes 'Credit Card Number' -MinCount 10 -Confidence High -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with PURVDLP-Discovery.ps1. .NOTES Purview — Data Loss Prevention. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), [string[]]$SensitiveTypes = @('Credit Card Number'), [int]$MinCount = 10, [ValidateSet('Low','Medium','High')][string]$Confidence = 'High', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

How to run: Preview an Exchange+Cloud simulation policy for the built-in Credit Card SIT: powershell -File .\PURVDLP-Config.ps1 -PolicyName 'DLP - Email PII - Simulation' `-Locations Exchange -SensitiveTypes 'Credit Card Number' -MinCount 10 -Confidence High -WhatIf Actually create it (still simulation mode): powershell -File .\PURVDLP-Config.ps1 -PolicyName 'DLP - Email PII - Simulation'` -Locations Exchange -SensitiveTypes 'Credit Card Number' -MinCount 10 -Confidence High -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with PURVDLP-Discovery.ps1. .NOTES Purview — Data Loss Prevention. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), [string[]]$SensitiveTypes = @('Credit Card Number'), [int]$MinCount = 10, [ValidateSet('Low','Medium','High')][string]$Confidence = 'High', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

PURVDLP-Discovery.ps1

Purpose: Builds the DLP baseline: every existing DLP compliance policy with its MODE (enforce vs simulation vs disabled) and the locations it covers, plus a summary of sensitive information types (built-in vs custom) and any EDM schemas available in the tenant. Read-only — makes no changes. Use it to see what already exists before you build simulation policies. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVDLP-Discovery.ps1 -CsvPath .\PURVDLP-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). EXPECTED RESULTS A console table of DLP policies (Name, Mode, Locations) and SIT coverage (built-in / custom / EDM counts), plus an optional CSV of the policy inventory. PASS signal: policies you expect to be in simulation report a Test* mode; anything already in Enable that you did not intend is flagged for review. .NOTES Purview — Data Loss Prevention (Endpoint, Cloud & Email). Read-only against Security & Compliance PowerShell. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\PURVDLP-Discovery.ps1 -CsvPath .\PURVDLP-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). EXPECTED RESULTS A console table of DLP policies (Name, Mode, Locations) and SIT coverage (built-in / custom / EDM counts), plus an optional CSV of the policy inventory. PASS signal: policies you expect to be in simulation report a Test* mode; anything already in Enable that you did not intend is flagged for review. .NOTES Purview — Data Loss Prevention (Endpoint, Cloud & Email). Read-only against Security & Compliance PowerShell. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

PURVDLP-EndpointReadiness.ps1

Purpose: Checks whether Endpoint DLP can actually function before you scope a Devices-location policy: (1) licensing signals for Endpoint DLP (E5 / E5 Compliance service plans) from Microsoft Graph, (2) whether any existing DLP policy uses the Endpoint (Devices) location, and (3) an environmental device-count signal (MDM/Intune-enrolled devices via Graph) as context. Read-only. NOTE: authoritative Purview device-onboarding state is viewed in the Purview portal (Settings > Device onboarding); enrolled-device counts here are context, not proof of onboarding. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVDLP-EndpointReadiness.ps1 Requires Microsoft Graph PowerShell (Organization.Read.All; DeviceManagementManagedDevices.Read.All for the device-count signal) and Security & Compliance PowerShell (Connect-IPPSSession) for the policy-location check. EXPECTED RESULTS A readiness summary. PASS signal: an Endpoint-DLP-capable plan is present AND devices are onboarded per the portal. FAIL/verify signal: no capable plan, or the Devices location is unavailable — resolve licensing/onboarding (Req 2.1/2.3) before building endpoint policies. .NOTES Purview — Data Loss Prevention (Endpoint). Read-only. Verify final onboarding state in the Purview portal. > [CmdletBinding()] param([string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\PURVDLP-EndpointReadiness.ps1 Requires Microsoft Graph PowerShell (Organization.Read.All; DeviceManagementManagedDevices.Read.All for the device-count signal) and Security & Compliance PowerShell (Connect-IPPSSession) for the policy-location check. EXPECTED RESULTS A readiness summary. PASS signal: an Endpoint-DLP-capable plan is present AND devices are onboarded per the portal. FAIL/verify signal: no capable plan, or the Devices location is unavailable — resolve licensing/onboarding (Req 2.1/2.3) before building endpoint policies. .NOTES Purview — Data Loss Prevention (Endpoint). Read-only. Verify final onboarding state in the Purview portal. > [CmdletBinding()] param([string]$UserPrincipalName)

PURVDLP-Report.ps1

Purpose: Exports DLP rule matches (Exchange, SharePoint/OneDrive, Teams, and Endpoint) over a time window so you can classify true-positive vs false-positive and compute the false-positive rate that gates simulation-to-enforcement. Works for policies in simulation AND enforcement — simulation matches are logged the same way. Read-only — queries Search-UnifiedAuditLog only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVDLP-Report.ps1 -Days 14 -CsvPath .\PURVDLP-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console breakdown of DLP matches by workload and by policy, and a per-event CSV (time, user, workload, policy, rule, SIT, action) with a blank 'Disposition' column for you to mark TP/FP. Compute FP rate = FP / (TP + FP). PASS gate: FP rate at/under the agreed threshold with true positives still present. .NOTES Purview — Data Loss Prevention. Read-only reporting from the unified audit log. No changes made. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\PURVDLP-Report.ps1 -Days 14 -CsvPath .\PURVDLP-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console breakdown of DLP matches by workload and by policy, and a per-event CSV (time, user, workload, policy, rule, SIT, action) with a blank 'Disposition' column for you to mark TP/FP. Compute FP rate = FP / (TP + FP). PASS gate: FP rate at/under the agreed threshold with true positives still present. .NOTES Purview — Data Loss Prevention. Read-only reporting from the unified audit log. No changes made. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$UserPrincipalName)

PURVDLP-Set-Scope.ps1

Purpose: Reports a DLP policy's current locations and mode, and — only with -Commit — narrows an Exchange/OneDrive/SharePoint/Teams policy to a PILOT RING by setting the location member-of scope (e.g. ExchangeSenderMemberOf / OneDriveSharedByMemberOf), so enforcement can be limited to a ring before tenant-wide expansion. Safe by default: -WhatIf reports only; writes require -Commit. This helper adjusts SCOPE only — it does NOT flip a policy to enforce (that is a deliberate portal/change-control action). HOW TO RUN Report current scope: powershell -File .\PURVDLP-Set-Scope.ps1 -PolicyName 'DLP - Email PII - Simulation' -WhatIf Restrict the Exchange policy to a pilot-ring group (still simulation mode): powershell -File .\PURVDLP-Set-Scope.ps1 -PolicyName 'DLP - Email PII - Simulation' ` -PilotRingGroup 'DLPPilotRing@contoso.com' -Location Exchange -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the current locations/mode and the Set-DlpCompliancePolicy call it WOULD run. -Commit: applies the member-of scope and re-prints it. PASS: the policy's *MemberOf scope now equals the pilot ring, and Mode is unchanged (still simulation until you enforce in the portal). .NOTES Purview — Data Loss Prevention. Scope changes gated behind -Commit; never changes enforcement mode. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [ValidateSet('Exchange','SharePoint','OneDrive','Teams')][string]$Location = 'Exchange', [string]$UserPrincipalName, [switch]$Commit)

How to run: Report current scope: powershell -File .\PURVDLP-Set-Scope.ps1 -PolicyName 'DLP - Email PII - Simulation' -WhatIf Restrict the Exchange policy to a pilot-ring group (still simulation mode): powershell -File .\PURVDLP-Set-Scope.ps1 -PolicyName 'DLP - Email PII - Simulation' ` -PilotRingGroup 'DLPPilotRing@contoso.com' -Location Exchange -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the current locations/mode and the

Set-DlpCompliancePolicy call it WOULD run. -Commit: applies the member-of scope and re-prints it. PASS: the policy's *MemberOf scope now equals the pilot ring, and Mode is unchanged (still simulation until you enforce in the portal). .NOTES Purview — Data Loss Prevention. Scope changes gated behind -Commit; never changes enforcement mode. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [ValidateSet('Exchange','SharePoint','OneDrive','Teams')][string]$Location = 'Exchange', [string]$UserPrincipalName, [switch]$Commit)